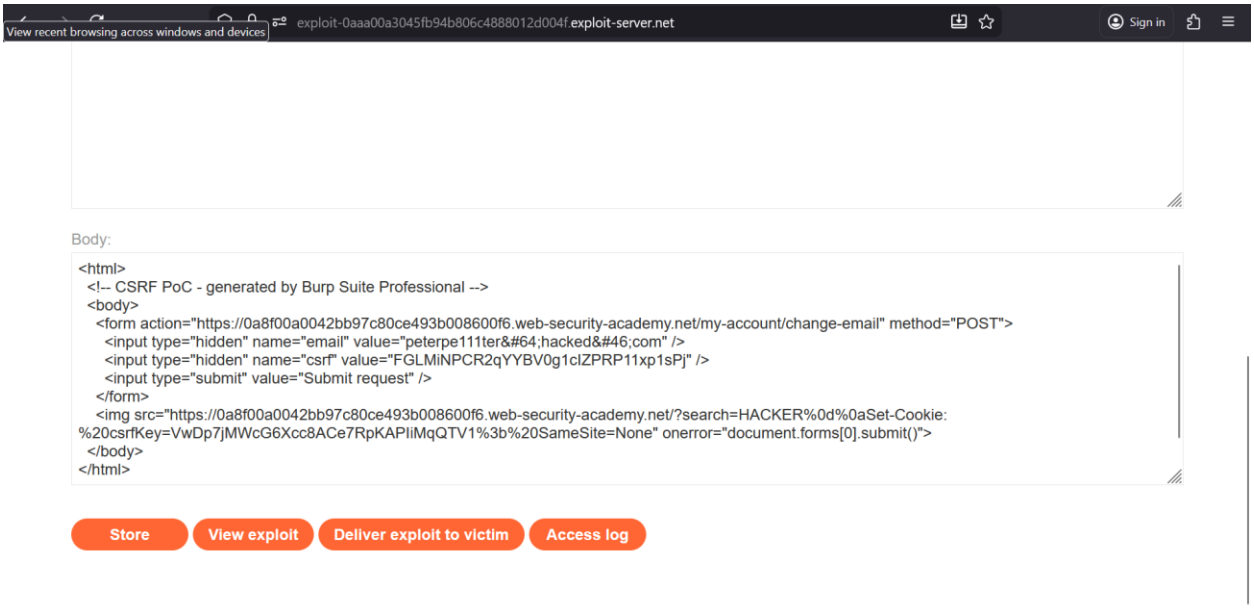
Title: CSRF Protection Bypass via Token–Session Decoupling

Cross-Site Request Forgery (CSRF) is an attack that forces an end user to execute unwanted actions on a web application in which they're currently authenticated. With a little help of social engineering (such as sending a link via email or chat), an attacker may trick the users of a web application into executing actions of the attacker's choosing. If the victim is a normal user, a successful CSRF attack can force the user to perform state changing requests like transferring funds, changing their email address, and so forth. If the victim is an administrative account, CSRF can compromise the entire web application.

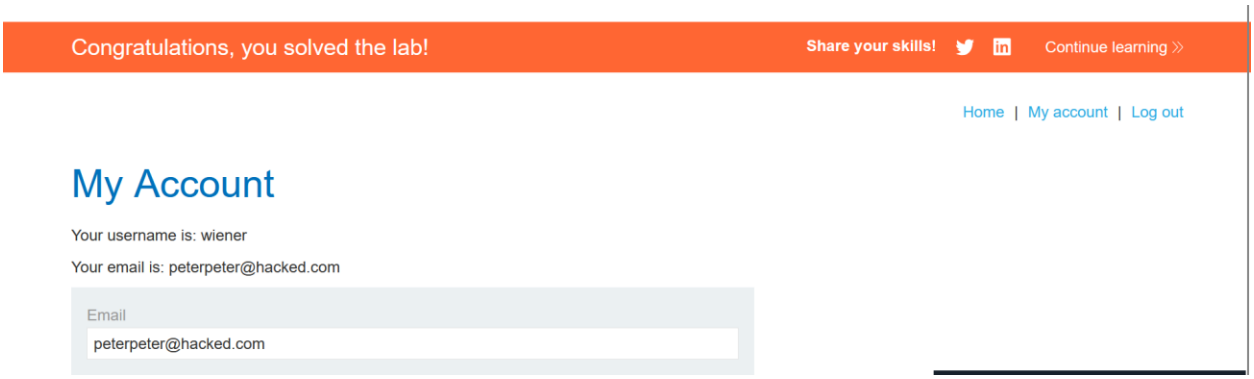
Reproduction steps:

1-visit: https://0a8f00a0042bb97c80ce493b008600f6.web-security-academy.net/

2-enter the user-1account(wiener) and the user-2(carlos)and get the CSRFKEY from the user and make this malicious code and but the CSRFKEY in it and run it on a server



3-now the server send the request to the victuim and change the email



Impact Statement:

A remote unauthenticated attacker can change the email address of any logged-in user without their knowledge or consent by luring them into visiting a single malicious page. This leads directly to full account takeover, as the attacker can subsequently trigger a password reset to the newly registered email address. No user interaction beyond the page visit is required, and the attack leaves no visible trace to the victim.

Recommended Mitigations:

- **Bind the CSRF token to the session:** The server must verify that the `csrfKey` cookie corresponds to the authenticated session, not merely that it matches the `csrf` form parameter.
- **Sanitize reflected input in response headers:** The search endpoint must strip or encode CR/LF characters (`%0d%0a`) from user input before it appears in any HTTP response header, eliminating the header injection vector used for cookie injection.
- **Apply `SameSite=Strict` or `SameSite=Lax` to session cookies:** This provides defense-in-depth by preventing the browser from sending session cookies on cross-origin requests entirely.